ĐẠI HỌC KINH TẾ QUỐC DÂN
KHOA CÔNG NGHỆ THÔNG TIN

Bài giảng

AN TOÀN VÀ BẢO MẬT THÔNG TIN

Chương 4: HÀM BĂM VÀ CHỮ KÝ ĐIỆN TỬ

ThS. Nguyễn Quốc Thái

NỘI DUNG CHƯƠNG

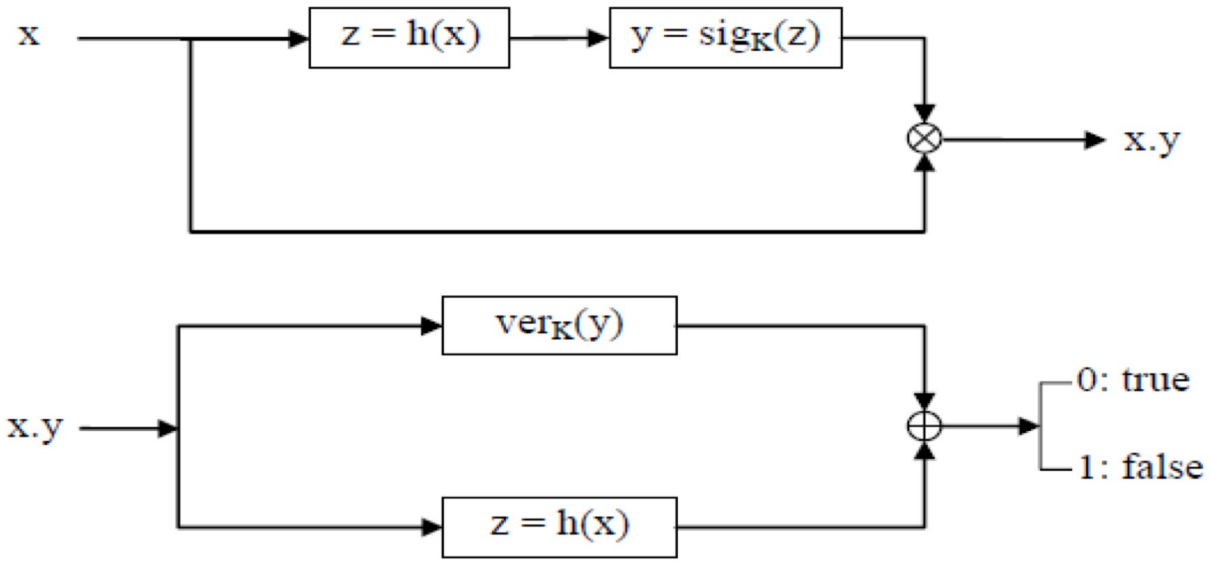
1. Hàm băm (hash function)
2. Chữ ký điện tử (digital signature)
3. Các hàm băm và chữ ký điện tử khác* (đọc nâng cao)

1 – HÀM BĂM (HASH FUNCTION)

- Khái niệm
- Tính chất của hàm băm
- Tấn công nghịch lý ngày sinh (birthday attack)
- Các hàm băm thông dụng
- Một số ứng dụng của hàm băm

1 – HÀM BĂM (HASH FUNCTION)

- **Khái niệm**
  - Một hàm băm H sẽ lấy ở đầu vào một thông tin X có kích thước biến thiên và sinh kết quả là một chuỗi có độ dài cố định, được gọi là cốt bức điện (message digest).
  - Ví dụ: Khi B muốn ký một bức điện x (độ dài bất kỳ), trước hết sẽ tính cốt bức điện z = h(x) (độ dài cố định) và sau đó ký y = $sig_K(z)$. Anh ta phát cặp (x,y) lên kênh truyền, bây giờ việc kiểm tra có thể thực hiện bằng việc tính lại cốt của bức điện z = h(x), sau đó kiểm tra $ver_K(z,y)$ có bằng TRUE hay không.
  - Một sơ đồ chữ ký sử dụng hàm băm:



1 – HÀM BĂM (HASH FUNCTION)

- **Tính chất của hàm băm**
  - Một hàm băm h có tính không đụng độ cao khi với một bức điện x cho trước, không tìm ra một bức điện x' ≠ x sao cho h(x') = h(x).
  - Một hàm băm h có tính đụng độ cao khi không thể tìm ra những bức điện x và x' sao cho x' ≠ x và h(x') = h(x).
  - Một hàm băm h có tính một chiều khi với cốt của một bức điện z cho trước không thể tìm được một bức điện x sao cho h(x) = z.

1 – HÀM BĂM (HASH FUNCTION)

- **Tấn công nghịch lý ngày sinh (Birthday Attack)**
  - Nghịch lý ngày sinh: Trong một nhóm có 23 người bất kỳ, xác suất để có 2 người có cùng ngày sinh nhật ít nhất là ½.
  - Tổng quát, giả sử một hàm băm có n giá trị băm khác nhau, nếu chúng ta có k giá trị băm từ k thông tin khác nhau được chọn ngẫu nhiên thì xác suất để không xảy ra đụng độ là: $1 - e^{-k(k-1)/2n} \approx \varepsilon$
  - Nghịch lý ngày sinh (công thức trên) cho phép dự đoán được chặn dưới của số lượng phép thử để tìm ra đụng độ của một hàm băm. Thực tế là: Một hàm băm 40 bít là không an toàn vì chỉ cần thử 2^{20} (khoảng 1 tỉ) phép thử thì đã có xác suất đụng độ là 50%.

1 – HÀM BĂM (HASH FUNCTION)

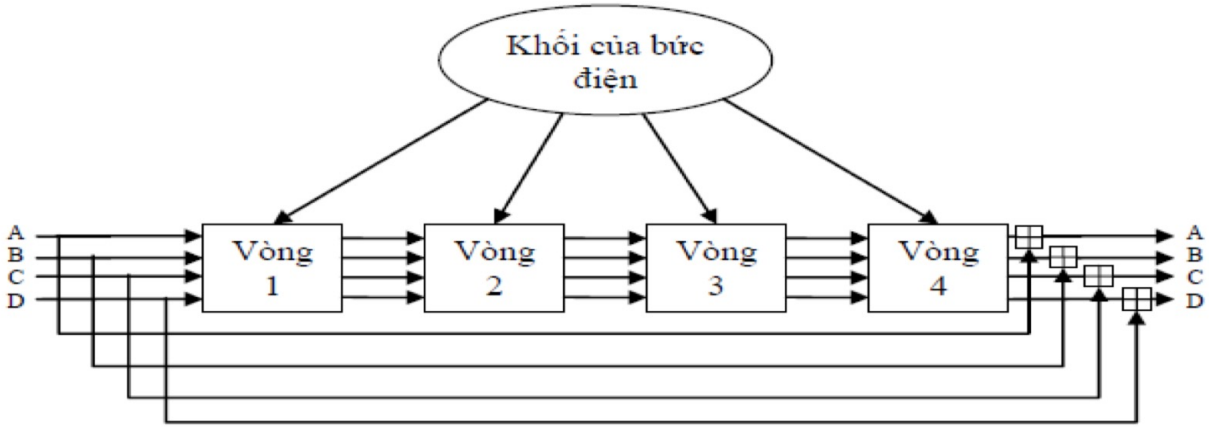
- **Các hàm băm phổ biến - MD5**
  - Hàm băm MD5 (Message Digest): Do Ronald Rivest phát minh (1991).
  - Tóm lược MD5:
    - Đầu vào là các khối 512 bít, được chia thành 16 khối con 32 bít. Đầu ra là thiết lập của 4 khối 32 bít để tạo thành 1 hàm băm 128 bít duy nhất.
    - Hoạt động:
      - Đầu tiên, chia bức điện thành các khối 512 bít, với khối cuối cùng (giả sử là x và x < 512 bít) của bức điện, ta cộng thêm một bít "1" vào cuối của x, tiếp theo đó là các bít "0" để được độ dài cần thiết (512 bít). Kết quả bức điện vào là 1 chuỗi M có độ dài chia hết cho 512; vì vậy chia M thành các N word (từ) 32 bít (N word này sẽ chia hết cho 16).
      - Tính cốt bức điện với 4 khối 32 bít A, B, C và D: A = 0x01234567; B = 0x89abcdef; C = 0xfedcba98; D = 0x76543210.
      - Bức điện được chia thành các khối 512 bít, mỗi khối 512 bít lại được chia tiếp thành 16 khối 32 bít để đi vào 4 vòng lặp của MD5. (mỗi vòng thực hiện 16 lần biến đổi với 1 hàm phi tuyến).
      - Đầu ra cuối cùng là một khối 128 bít của A, B, C và D => Đây là hàm băm MD5 nhận được.

1 – HÀM BĂM (HASH FUNCTION)

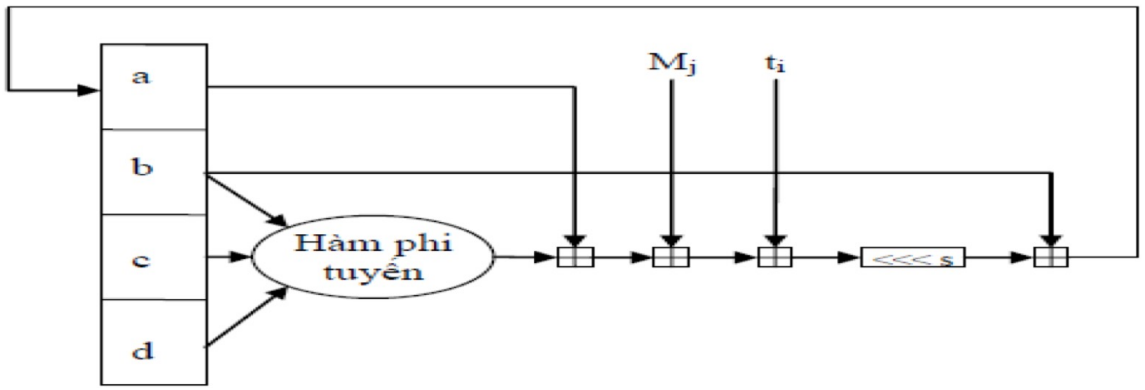
- **Các hàm băm phổ biến - MD5**
  - Hàm băm MD5 (Message Digest): Do Ronald Rivest phát minh (1991).
  - Tóm lược MD5:
    - Sơ đồ 4 vòng lặp của MD5:

    Ký hiệu: ⊞ (phép OR)

    <<<s (phép dịch trái s bít)



    - Sơ đồ 1 vòng lặp của MD5



8 bit

Thanh ghi a=10, b=20, c=30, d=40

F(b,c,d) = (b AND c) or d

Mj = 50

ti = 60

S = 3

T = (a + F(b,c,d) + Mj + ti) <<< s

A new = d

B new = b + T

C new = b

D new = c

1 – HÀM BĂM (HASH FUNCTION)

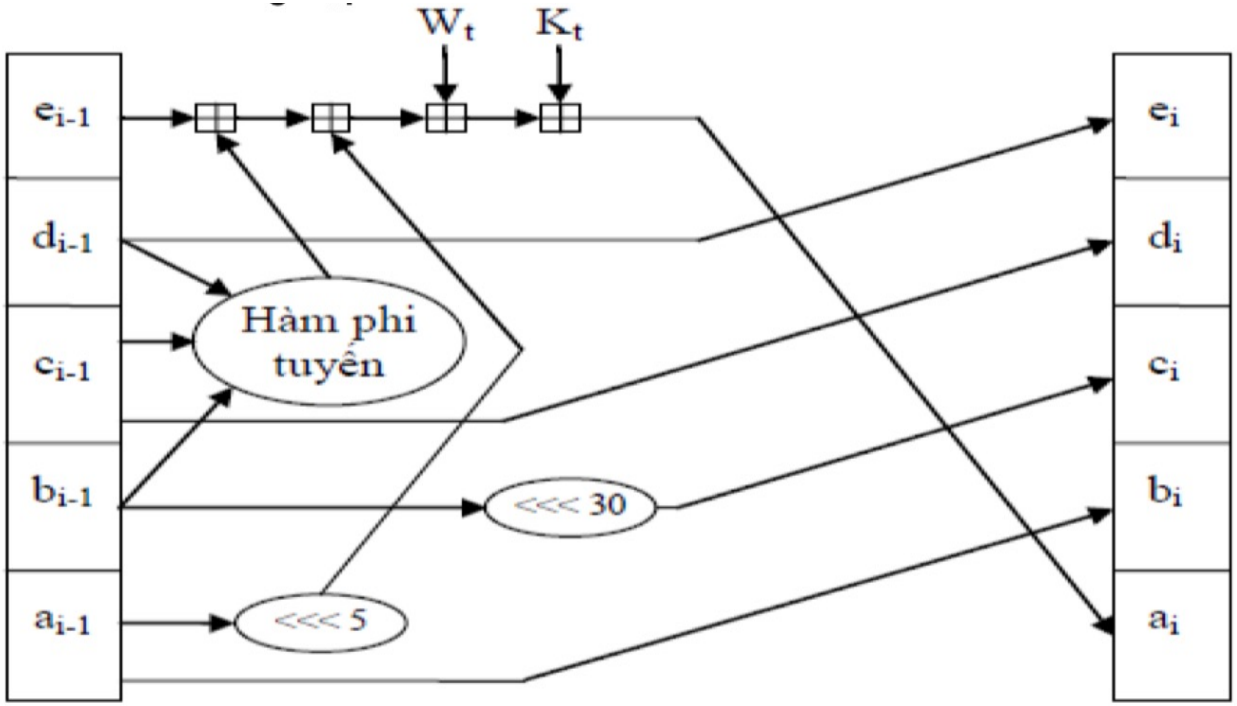
- **Các hàm băm phổ biến - MD5**
  - Hàm băm MD5 (Message Digest): Do Ronald Rivest phát minh (1991).
  - **Bảo mật trong MD5**
    - Thêm vòng thứ 4.
    - Mỗi bước được cộng thêm 1 hằng số.
    - Mỗi bước được cộng kết quả của bước trước đó, làm cho các quá trình có tính liên kết, phụ thuộc lẫn nhau.
    - Việc các khối con bị thay đổi khi vào vòng 2 và vòng 3 làm cho khuôn dạng cấu trúc vòng lặp thay đổi theo.
    - Số lượng bít dịch trái của mỗi vòng được tối ưu, các bước dịch ở mỗi vòng khác nhau.

1 – HÀM BĂM (HASH FUNCTION)

- **Các hàm băm phổ biến - SHA**
  - Hàm băm SHA (Secure Hash Algorithm): Do tổ chức NIST cùng NSA thiết kế (1995).
  - Tóm lược SHA:
    - Dựa trên nguyên tắc của MD4/MD5, tạo ra 160 bít giá trị băm.
    - Hoạt động:
      - Tính cốt bức điện: Giống với MD5, bức điện được cộng thêm một bít "1" và các bít "0" ở cuối bức điện để chia hết cho 512. SHA sử dụng 5 thanh ghi dịch: A = 0x67452301, B = 0xefcdab89, C = 0x98badcfe, D = 0x10325476, E = 0xc3d2e1f0.
      - Bức điện được chia thành các khối 512 bít, có 4 vòng lặp chính (mỗi vòng thực hiện 20 lần biến đổi với 1 hàm phi tuyến).
      - Đầu ra là 1 khối 160 bít của A, B, C, D và E => Là hàm băm SHA 160 bít.

1 – HÀM BĂM (HASH FUNCTION)

- **Các hàm băm phổ biến - SHA**
  - Hàm băm SHA (Secure Hash Algorithm): Do tổ chức NIST cùng NSA thiết kế (1995).
  - Tóm lược SHA:
    - Sơ đồ 1 vòng lặp của SHA:



1 – HÀM BĂM (HASH FUNCTION)

- **Các hàm băm phổ biến - SHA**
  - Hàm băm SHA (Secure Hash Algorithm): Do tổ chức NIST cùng NSA thiết kế (1995).
  - **Bảo mật trong SHA**
    - SHA đều cộng thêm các bít "giả" để tạo thành các khối chia hết cho 512 bít, SHA sử dụng cùng 1 hàm phi tuyến f cho cả 4 vòng.
    - SHA sử dụng mỗi hằng số cho mỗi vòng biến đổi, hằng số dịch này là một số nguyên tố đối với độ lớn của từ (word).
    - SHA sử dụng hàm phi tuyến của MD4 (phiên bản trước MD5).
    - Trong SHA, cộng thêm cột thứ 5.

1 – HÀM BĂM (HASH FUNCTION)

- **Một số ứng dụng của hàm băm**
  - Các hệ chữ ký điện tử, xác thực thông điệp, xác thực người dùng.
  - Xác thực tính nguyên vẹn thông điệp.
  - Lưu mật khẩu người dùng.
  - Bảo mật thông tin giao dịch trong thương mại điện tử.

2 – CHỮ KÝ ĐIỆN TỬ (DIGITAL SIGNATURE)

- Khái niệm
- Hệ chữ ký RSA
- Chuẩn chữ ký điện tử (digital signature standard)
- Mô hình ứng dụng chữ ký điện tử

2 – CHỮ KÝ ĐIỆN TỬ (DIGITAL SIGNATURE)

- **Khái niệm**
  - Các điểm khác biệt cơ bản giữa CKĐT và chữ ký thông thường: Vấn đề ký một tài liệu, vấn đề kiểm tra và bản sao chép (copy) tài liệu với CKĐT đồng nhất với bản gốc.
  - Sơ đồ chữ ký điện tử (CKĐT): Là phương pháp ký một văn bản (hoặc lưu bức điện) dưới dạng điện tử. Sơ đồ CKĐT thường gồm 2 thành phần: Thuật toán ký sig() và thuật toán xác minh ver() (nghĩa là: B có thể ký một bức điện x dùng thuật toán ký an toàn, kết quả chữ ký y = sig(x) nhận được có thể được kiểm tra bằng thuật toán xác minh công khai ver(y). Khi cho trước cặp (x,y), thuật toán xác minh cho giá trị TRUE/FALSE tuỳ thuộc vào kết quả chữ ký được xác thực).
  - Khái niệm chữ ký điện tử:
    - Định danh điện tử được tạo ra bởi máy tính được người dùng/tổ chức sử dụng nhằm đạt được hiệu quả và có hiệu lực như chữ ký tay.
    - Cơ chế xác thực cho phép người tạo thông điệp đính kèm 1 mã vào thông điệp giống như việc ký 1 chữ ký lên văn bản bình thường.
    - CKĐT được sinh ra và sử dụng bởi các hệ (sơ đồ) chữ ký điện tử.

2 – CHỮ KÝ ĐIỆN TỬ (DIGITAL SIGNATURE)

- **Khái niệm**
  - Định nghĩa: Một sơ đồ chữ ký điện tử là bộ 5 tham số (P, A, K, S, V); trong đó:
    - 1) P là tập hữu hạn các bức điện (thông điệp, bản rõ).
    - 2) A là tập hữu hạn các chữ ký.
    - 3) K là tập không gian khoá (tập hữu hạn các khoá có thể).
    - 4) Với mỗi khoá $k \in K$ tồn tại 1 thuật toán ký $sig_k \in S$ và 1 thuật toán xác minh $ver_k \in V$. Mỗi sig_k: $P \rightarrow A$ và ver_k: $P \times A \rightarrow \{TRUE, FALSE\}$ là những hàm sao cho mỗi bức điện $x \in P$ và mỗi chữ ký $y \in A$ thoả mãn:

      Ver(x, y) = { TRUE nếu y = sig(x) | FALSE nếu y ≠ sig(x) }
  - Hàm ver_k sẽ là hàm công khai, còn hàm sig_k là bí mật.
  - Sơ đồ CKĐT đảm bảo an toàn tính toán.

2 – CHỮ KÝ ĐIỆN TỬ (DIGITAL SIGNATURE)

- **Hệ chữ ký điện tử RSA**
  - Hệ chữ ký điện tử RSA: Chỉ cần đảo ngược hàm mã hoá và giải mã trong hệ mã hóa công khai RSA.
  - Sơ đồ chữ ký điện tử RSA:
    - Cho n = p*q; trong đó: p, q là các số nguyên tố. Đặt P = A = Z_n và định nghĩa: K = {(n, p, q, a, b): n = p*q; p và q là các số nguyên tố, ab ≡ 1 (mod φ(n))}; với n và b công khai, còn p, q, a giữ bí mật.
    - Với K = (n, p, q, a, b), xác định: $sig_K(x) = x^a \bmod n$ và $ver_K(x,y) = TRUE \Leftrightarrow x \equiv y^b \bmod n$; với $x,y \in Z_n$.
  - Chữ ký thường được kết hợp với hàm mã hoá công khai: Giả sử A (người gửi) muốn gửi 1 bức điện đã được mã hoá và đã ký đến cho B (người nhận). Với bản rõ x, A sẽ tính chữ ký của A là $y = sig_A(x)$, sau đó mã hoá cả x và y sử dụng khoá công khai e_B của B, kết quả nhận được là bản mã $z = e_B(x,y)$. Bản mã z sẽ được gửi tới B, khi B nhận được z, B sẽ giải mã với khóa giải mã d_B của B để nhận được (x,y), tiếp theo B sẽ sử dụng hàm xác minh công khai của A để kiểm tra xem $ver_A(x,y) = TRUE$?

2 – CHỮ KÝ ĐIỆN TỬ (DIGITAL SIGNATURE)

- **Chuẩn chữ ký điện tử (Digital Signature Standard - DSS)**
  - Thuật toán chữ ký điện tử (Digital Signature Algorithm - DSA): Do NIST (1991), là cơ sở cho chuẩn CKĐT, đây là biến thể của thuật toán ElGamal.
  - **Thuật toán:**
    - 1) Chọn 1 số nguyên tố q sao cho: $2^{159} < q < 2^{160}$.
    - 2) Chọn số t sao cho $0 \leq t \leq 8$ và 1 số nguyên tố p sao cho: $2^{511+64*t} < p < 2^{512+64*t}$ và q chia hết (p-1).
    - 3) Tạo 1 số α duy nhất cho q trong trường Z_p^*: Chọn một giá trị $g \in Z_p^*$ và tính $\alpha = g^{(p-1)/q} \bmod p$. Nếu α = 1 thì quay lại bước trên (chọn lại giá trị g cho phù hợp).
    - 4) Chọn 1 số nguyên ngẫu nhiên a sao cho: $1 \leq a \leq q-1$.
    - 5) Tính $y = \alpha^a \bmod p$.
    - 6) Khoá ký là (p, q, α, y) được công khai và a là khoá bí mật.

2 – CHỮ KÝ ĐIỆN TỬ (DIGITAL SIGNATURE)

- **Chuẩn chữ ký điện tử (Digital Signature Standard - DSS)**
  - Chuẩn chữ ký điện tử: Cho p là 1 số nguyên tố 512 bít trong trường logarit rời rạc Z_p^*; q là 1 số nguyên tố 160 bít và q chia hết (p-1). Cho $\alpha \in Z_p^*$; $P = Z_p^*$, $A = Z_q \times Z_q$, và định nghĩa:
    - $K = \{(p, q, \alpha, a, \beta): \beta \equiv \alpha^a (\text{mod } p)\}$; trong đó giá trị p, q, α và β là công khai, còn a là bí mật.
    - Với $K = (p, q, \alpha, a, \beta)$ và chọn 1 số ngẫu nhiên k ($1 \le k \le q-1$), định nghĩa: $sig_k(x, k) = (\gamma, \delta)$; trong đó: $\gamma = (\alpha^k \text{ mod } p) \text{ mod } q$ và $\delta = (x + a*\gamma)k^{-1} \text{ mod } q$.
    - Với $x \in Z_p^*$ và $\gamma, \delta \in Z_q$, việc xác minh được thực hiên bằng cách tính:
      - $e_1 = x^{-1} \text{ mod } q$
      - $e_2 = \gamma\delta^{-1} \text{ mod } q$
      - $ver(x, \gamma, \delta) = \text{TRUE} \Leftrightarrow (\alpha^{e_1} \beta^{e_2} \text{ mod } p) \text{ mod } q = \gamma$

2 – CHỮ KÝ ĐIỆN TỬ (DIGITAL SIGNATURE)

- **Chuẩn chữ ký điện tử (Digital Signature Standard - DSS)**
  - BTVD: Chọn q = 101 và p = 78*q + 1 = 7879 và g = 3 là một số nguyên tố trong Z_{7879}.
  - **Giải: Ta có thể tính toán:**

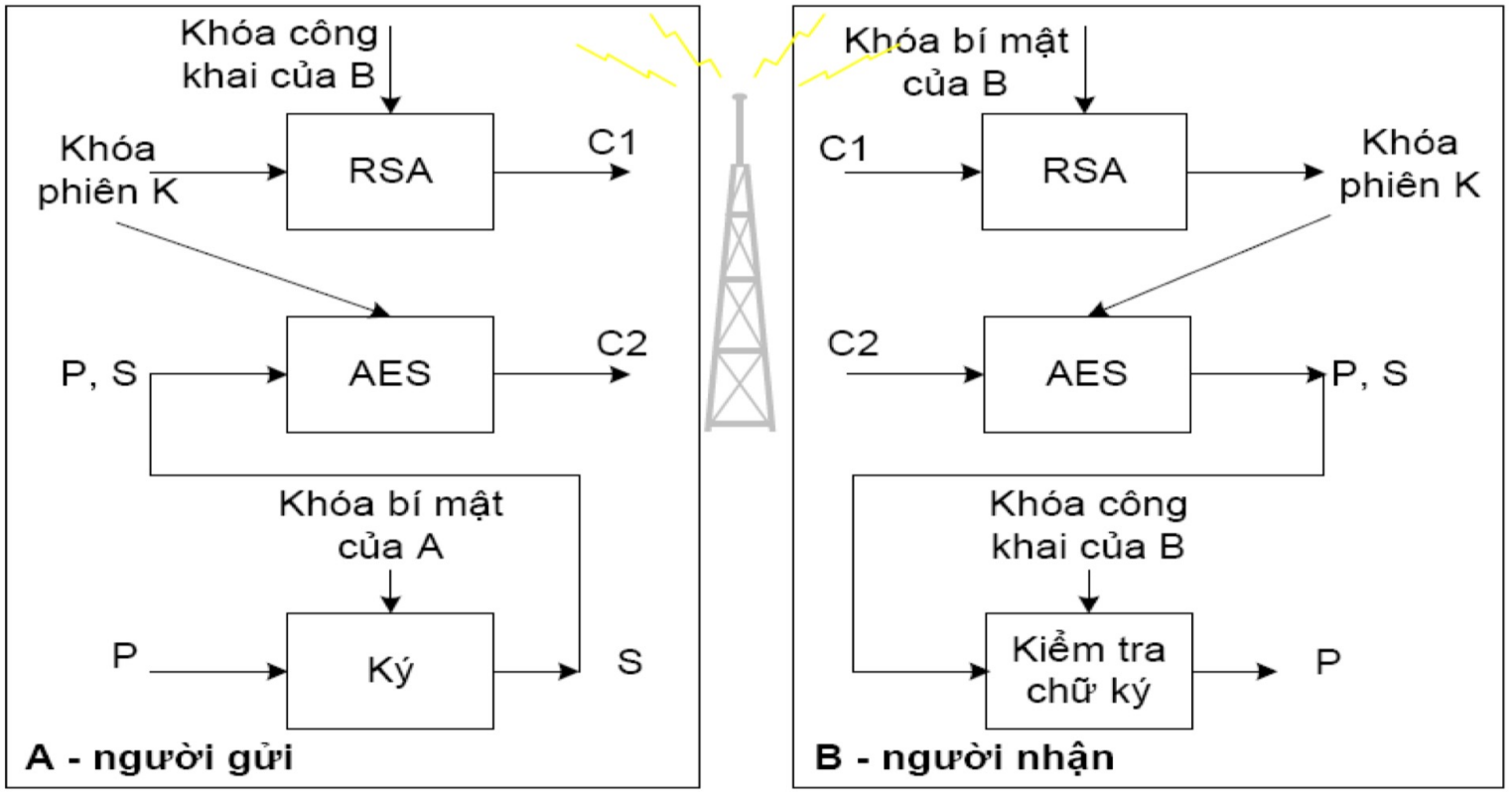
    $\alpha = 3^{78} \bmod 7879 = 170$
    Chọn a = 75, do đó: $\beta = \alpha^a \bmod 7879 = 170^{75} \bmod 7879 = 4567$
    Giả sử B muốn ký bức điện x = 1234, B chọn số ngẫu nhiên k = 50 và tính: $k^{-1} \bmod 101 = 50^{-1} \bmod 101 = 99$
    $\gamma = (170^{50} \bmod 7879) \bmod 101 = 2518 \bmod 101 = 94$
    $\delta = (1234 + 75*94)99 \bmod 101 = 97$
    => Cặp chữ ký (94, 97) cho bức điện 1234 được xác thực:
    $\delta^{-1} = 97^{-1} \bmod 101 = 25$
    $e_1 = 1234*25 \bmod 101 = 45$
    $e_2 = 94*25 \bmod 101 = 27$
    $(170^{45}\ 4567^{27} \bmod 7879) \bmod 101 = 2518 \bmod 101 = 94 = \gamma$
    => Kết luận: Đúng chữ ký.

2 – CHỮ KÝ ĐIỆN TỬ (DIGITAL SIGNATURE)

- **Mô hình ứng dụng chữ ký điện tử**
  - CKĐT được gửi đi cùng với thông điệp, người nhận nhận được thông điệp, chữ ký tương ứng và thực hiện thuật toán kiểm tra chữ ký có đúng là của người gửi ký lên văn bản nhận được hay không.
  - Sơ đồ hoạt động:
    - Bên A (người gửi): Khoá phiên K → RSA (với Khoá công khai B) → C1 | P, S → AES (với Khoá bí mật A) → C2
    - Bên B (người nhận): C1 → RSA (với Khoá bí mật B) → Khoá phiên K | C2 → AES (với Khoá công khai B) → P, S | P → Kiểm tra chữ ký (với Khoá công khai A) → P

2 – CHỮ KÝ ĐIỆN TỬ (DIGITAL SIGNATURE)

- **Mô hình ứng dụng chữ ký điện tử**
  - CKĐT được gửi đi cùng với thông điệp, người nhận nhận được thông điệp, chữ ký tương ứng và thực hiện thuật toán kiểm tra chữ ký có đúng là của người gửi ký lên văn bản nhận được hay không.
  - Sơ đồ hoạt động:



TÓM TẮT NỘI DUNG CHƯƠNG 4

- Trao đổi/thảo luận nhóm
- Bài tập/Thực hành
- Tóm tắt nội dung
- Câu hỏi và bài tập ôn tập



CASE STUDY, BÀI TẬP NHÓM & KIỂM TRA

- Case study
- Bài tập nhóm/Tiểu luận
- Bài kiểm tra



HƯỚNG DẪN ÔN TẬP

- Tổng kết nội dung môn học
- Đề cương ôn tập

